



File No.: EXP202102432

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On August 4, 2021, A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection. The complaint is directed against the MINISTRY OF INCLUSION, SOCIAL SECURITY AND MIGRATIONS, GENERAL SUBDIRECTORATE OF HUMAN RESOURCES AND GENERAL INSPECTION OF SERVICES, with NIF S2801449F (hereinafter, the Ministry). The reasons for the complaint are as follows:

The complainant states that the General Subdirectorate of Human Resources and Inspection of Services sent an email to a third party containing the response letter from the General Subdirectorate of Human Resources and Inspection of Services, of the Ministry of Inclusion, Social Security and Migrations, which resolved his request for cessation and reflected aspects and information related to his employment circumstances that allowed for his identification, thereby violating the confidentiality in the processing of his data.

Along with the complaint, the following documents are submitted:

- Written request dated June 15, 2021, in which he requests a resolution for his cessation from his position and, if applicable, a report on all Free Appointments that have occurred within the ***POSITION.1 in the last 4 years.
- Response letter from the General Subdirectorate of Human Resources and Inspection of Services, of the Ministry of Inclusion, Social Security and Migrations, dated July 23, 2021.
- Image of the email sent by the aforementioned General Subdirectorate to the complainant forwarding the response letter, dated July 26, 2021.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the Ministry for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in the data protection regulations.

The forwarding, which was carried out in accordance with the provisions of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) through electronic notification, was not acknowledged by the responsible party within the availability period, being understood as rejected in accordance with the provisions of Article 43.2 of the LPACAP on October 11, 2021, as stated in the certificate in the file.

Although the notification was validly carried out by electronic means, with the procedure being considered completed in accordance with Article 41.5 of the LPACAP, an informational copy was sent by postal mail, which was duly notified on October 27, 2021. In this notification, he was reminded of his obligation to interact electronically with the Administration, and he was informed of the means of access to such notifications, reiterating that, henceforth, notifications would be made exclusively by electronic means.

No response has been received to this forwarding letter.

THIRD: On December 16, 2021, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: The General Subdirectorate of Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the following aspects:

Facts according to the statements of the complainant:

(...)

Date on which the complained facts occurred: July 22, 2021.

In response to the request for information, the representative of the Ministry states the following:
(...)

FIFTH: On October 28, 2022, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the Ministry, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.5 of the GDPR and Article 83.4 of the GDPR respectively.

SIXTH: On November 11, 2022, the Ministry submitted a written request through which it requested a copy of the file, as well as an extension of the deadline to present allegations.

SEVENTH: On November 14, 2022, the instructing body agreed to extend the requested deadline by a maximum of five days, in accordance with the provisions of Article 32.1 of the LPACAP.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/27

The extension agreement is notified to the Ministry on the same day, as evidenced by the acknowledgment of receipt in the file.

EIGHTH: On November 22, 2022, a written communication from the Ministry was received by this Agency, in due time and form, in which it presents allegations regarding the initiation agreement, which, in summary, states that:

First. - Administrative error and proactive conduct for immediate rectification.

The Ministry admits that, due to human error, a resolution that addressed a request for information from the claimant was directed in the heading of the document, and consequently notified, to another person, whose name and surname appeared. It understands that the error would be legally classified as a mere material error, consisting of changing one name and surname for another name and surname in a resolution, and that it was immediately detected and rectified within two business days by correcting the resolution and sending the document to its correct recipient. The corrected document, signed on 07/23/2022, is attached.

Second. - Concurrent similarities that facilitated the commission of a material error.

The Ministry indicates that the confusion of one name (that of the respondent) for another (C.C.C.) in the heading as the recipient of the administrative document originates from the circumstance that two requests were being resolved that shared numerous similarities:

(...)

On Thursday, 07/22/2021, the document addressed to C.C.C. was sent, the content of which corresponded to the request for cessation and public information submitted by the claimant.

Two business days later, on Monday, 07/26/2021, the error was rectified by notifying the document to its correct recipient.

Third. - Information requested by the claimant.

The Ministry points out that, as evidenced (pages 7 to 15 of the administrative file), the claimant's request consists of 3 petitions, in summary, the following:

1. "That a cessation resolution be issued.
2. That, subsidiarily, an express resolution be issued that grounds the decision not to give effect (...)
3. That "For the previous case, it is requested, prior to its request to the Transparency Council, that a report be issued on all the Free Designations that have occurred within the ***POSITION.1 in the last four years, with reference to the favorable or unfavorable reports that have been issued in each of them."

Fourth. - Disagreement with the claimant's assessment of the facts.

The Ministry, entering into a more detailed assessment of the facts reported by the claimant in the section "Description of the facts" in Annex 1 (page 8 of the administrative file), understands that they do not faithfully reflect reality, for the following reasons:

1. Contrary to what the respondent states, <>. Said document was only notified to one person, not to several colleagues, and, a priori, the fact that it is located in another province or legal service is indifferent. The information revealed does not cause true harm to the interested party, so it should not be considered as a significant security/confidentiality breach.
2. The signing of a collective letter addressed to a public official, specifically to the Director of the Legal Service, would not in itself constitute personal information, as it is not a private or personal document of the claimant. There is also no perceived risk of exposing them to an uncomfortable or delicate situation by stating that there are not sufficient staff, a circumstance that is continuously reported by employees and unions regarding various services and public administrations (health services, Social Security, etc.).
3. The information on free designations in the last 4 years is provided in exercise of the right of access to information, as provided in Article 105.b) of the Constitution, and constitutes public information in accordance with the provisions of Law 19/2013, of December 9, on transparency, access to information, and good governance.

As defined in Article 13 of Law 19/2013, of December 9, public information is understood to be the contents or documents, regardless of their format or medium, that are in the possession of any of the subjects included in the scope of application of this title (Title I) and that have been prepared or acquired in the exercise of their functions.

The processes for filling positions in public administrations are subject, among others, to the constitutional principles of publicity, equality, competition, etc., developed in Royal Legislative Decree 5/2015, of October 30, which approves the Consolidated Text of the Basic Statute of Public Employees and related regulations.

The information provided does not include personal data, is public, and does not reveal a supposed existence of a good or bad personal relationship with the Directorate of the Legal Service.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/27

4. In the official document subject to the claim, there is no reference to supposed "administrative and judicial diatribes that I currently maintain with them." This is an assertion of uncertain scope and without apparent foundation.
5. The alleged connection between human error and the means of notification is also uncertain, as if the official document had been notified by a means other than email, for example, to the Citizen Folder of the person listed in the document as the recipient, B.B.B. would have also accessed the resolution through their electronic certificate. The error lies in the name recorded, not in the method by which the notification was made.

In light of the above, the Ministry concludes that the version of the facts provided by the claimant is subjective, distorted, and may correspond to a reactive attitude due to not having obtained their administrative request, that is, the cessation of their position to take another position in another administration.

Fifth.- Assessment of the information from the claimant, provided to a third party.

The Ministry indicates that, in view of the content of the resolution mistakenly addressed to C.C.C. (pages 16 to 19 of the administrative file), it is noted that:

1. No personal data of the claimant is recorded.
2. The information regarding the allocation of the position at the City Council of Madrid is public and notorious, and is published in the ***BOLETIN.1. It is indeed an identifiable element, but it is public information.
3. The information regarding the circumstances of the claimant made available to C.C.C. does not reveal any information that they did not already know; on the contrary, it confirms the unity of criteria in the resolution of a factual situation coinciding with that of the recipient, since under identical circumstances, the MISSM has resolved in the same manner and with the same motivation: the request for cessation is not favorably resolved due to having been informed unfavorably by the Legal

Service of the INSS.

4. The remaining information, relating to the reports issued regarding appointments made by free designation in the last four years within the ***PUESTO.1, is public information that does not contain any personal data.

Sixth. Legal qualification.

The Ministry indicates that in the agreement to initiate the sanctioning procedure, the facts are classified as a presumed infringement of Article 5.1.f, typified in Article 83.5, and also the presumed infringement of Article 32, typified in Article 83.4 of the General Data Protection Regulation (GDPR).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/27

The commission of both infringements is subject to the imposition of a warning sanction.

However, the Ministry considers that the facts do not fall under this classification for the following reasons:

1. There is no infringement of the provision in Article 5.1.f) of the GDPR because the human error consisting of directing an official document in the name of another person, by the official who was processing and resolving two administrative files that had substantial identity and intimate connection, could not have been avoided through the adoption of different security measures, whether technical or of any other nature, in the processing and in matters of personal data protection.

2. The facts would also not fall under the infringement of the provisions established in Article 32 of the GDPR because, similarly, the application of technical and organizational measures to ensure an adequate level of security to the risk could not have prevented the confusion of an official in assigning the name of the recipient of an official document.

Indeed, taking into account the state of the art, implementation costs, nature, scope, context, purposes of the processing, etc., the technical and organizational measures that could be applied, such as pseudonymization, encryption of personal data, verification processes, and regular evaluation of effectiveness to ensure the security of processing, or other technical, organizational, or analogous measures, could not have prevented the human error committed due to the numerous similarities and points of coincidence between two administrative files being resolved simultaneously.

Therefore, the Ministry indicates that the legal qualification that this factual situation deserves is provided for in Article 109.2 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, which establishes, in relation to the revocation of acts and rectification of errors, that:

2. Public Administrations may also rectify at any time, ex officio or at the request of interested parties, material, factual, or arithmetic errors existing in their acts.

The procedural law regulates this type of material errors in general, given their understandable and inevitable occurrence in the ordinary processing of administrative procedures.

Based on all of the above, the Ministry concludes that:

1. The incident originates from the confusion in the name of the recipient of an official document, in the context of resolving two files that have substantial identity and intimate connection.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/27

No serious harm to the interested party is perceived that would justify classifying this incident as a "security or confidentiality breach."

2. The content of the information disclosed is of an eminently public nature, without any personal data being compromised, nor can it be classified as sensitive or relevant.

3. Action was taken proactively and without delay, through the immediate rectification of the error

committed.

4. Regardless of all the security measures in place, human error is 100% inevitable, even in this case involving a civil servant of recognized competence and professional diligence.

5. Nevertheless, efforts will be made to identify procedural measures to prevent similar situations from occurring in the future.

In light of the above, the Ministry requests that the file opened for alleged violations under Articles 5.1.f and 32 of the GDPR be closed.

NINTH: On June 6, 2023, the instructing body of the sanctioning procedure proposed a resolution, in which it proposes that the Director of the AEPD impose on the MINISTRY OF INCLUSION, SOCIAL SECURITY AND MIGRATIONS, with NIF S2801449F:

- for a violation of Article 5.1.f) of the GDPR, classified under Article 83.5 of the GDPR, a sanction of WARNING

- for a violation of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, a sanction of WARNING

This proposal for resolution, which was notified to the Ministry in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was received on June 7, 2023, as evidenced by the acknowledgment of receipt in the file. In this proposal for resolution, in response to the allegations made by the Ministry, the following response was provided:

First. - Disagreement with the assessment of the facts

In this section, the Ministry's allegations are consolidated, stating that, on the one hand, it does not agree with the assessment of the facts made by the complainant, and on the other, that personal data has not been affected and that, moreover, it is public information.

In this regard, it should be noted that, despite the complainant referring to a plurality of recipients or any other subjective considerations, the present sanctioning procedure is being processed due to the communication of personal data to an unauthorized third party, that is, to a single person, thereby violating the duty of confidentiality of personal data.

Regarding the assertion that the disclosed information does not cause serious harm to the complainant, it should be noted that the harm is inherent in the very violation of the confidentiality of the data, as this implies a loss of control and power of disposition over the same, constituting a violation of the fundamental right to the protection of personal data.

It should be recalled that, in accordance with data protection regulations, personal data is subject to a duty of confidentiality and cannot be communicated to a third party unless there is consent from the data subject or any other circumstances that make the processing lawful, in accordance with Article 6.1 of the GDPR.

Regarding the Ministry's statement that the disclosed information does not contain personal data, it is indicated, on the contrary, that information about certain employment-related circumstances, such as cessation requests made by the complainant, their denial, as well as requests and denials of the necessary authorizations concerning the provision of jobs in the Public Administration, are personal data, as they relate to an identified person and are not public data, as understood by the Ministry, regardless of the fact that the final allocation of jobs must be published in the corresponding Official Bulletin (but not the authorizations, cessations, denials, processing errors, and other procedures and vicissitudes that form or may form part of the process).

Second. - Legal qualification

The Ministry argues in this section that the facts do not constitute a violation of Article 5.1.f) or Article 32 of the GDPR, as it was due to human error, classified as a mere material error regulated in Article 109.2 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations.

In response, it should be noted that we are not dealing with a material error contained in an administrative act (which is susceptible to correction through another administrative act), but rather a violation of the confidentiality of personal data that was communicated to an unauthorized third party. Therefore, the error alleged by the Ministry does not lie in the content of the Official Letter (administrative act) sent, but in having sent it to another person and not to its intended recipient,

thereby violating, as indicated, the confidentiality of the personal data contained in that Official Letter. For all the above reasons, the allegations made are dismissed.

TENTH: On June 21, 2023, a letter from the Ministry was received in this Agency, in due time and form, in which it presents allegations to the proposed resolution, summarizing that:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/27

First. Absence of Guilt

It is alleged that it cannot be considered that the actions were carried out with intent, recklessness, negligence, or excusable ignorance, in relation to the regulations on data protection.

Thus, it is argued that the triggering circumstance of the breach of data confidentiality resulted from a mere material error, partly induced by the concurrent circumstances of the case, which occurred due to the simultaneous processing of two requests that shared numerous similarities.

It is understood that the existence of guilt towards the Ministry has not been reasoned. This lack of guilt, along with the error of considering that having adopted security measures would have prevented the breach of confidentiality, when we are facing a human error induced by the concurrent circumstances of the case, where there are no reasonable security measures in accordance with the risk that would have posed or would have allowed for a mitigation of the threat, constitutes an arbitrary application of the law and the imposition of objective liability.

This issue is of particular relevance and constitutes one of the Principles that must govern the sanctioning power, and thus, Article 28 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector, establishes that “1. Only individuals and legal entities [...] who are responsible for acts constituting administrative infractions may be sanctioned for such acts on the basis of intent or fault.”

It invokes the Judgment of the Constitutional Court No. 246/1991, of December 19, which states: “(...) Specifically, regarding guilt, this Court has declared that, indeed, the Spanish Constitution undoubtedly enshrines the principle of guilt as a basic structural principle of Criminal Law and has added that, however, the constitutional enshrinement of this principle does not imply in any way that the Constitution has converted a specific way of understanding it into a norm (STC 150/1991). This principle of guilt also governs in matters of administrative infractions, since to the extent that the sanction for such an infraction is one of the manifestations of the State's *ius puniendi*, a regime of objective liability or liability without fault is inadmissible in our legal system (STC 76/1990).”

The Ministry indicates that the concept of zero risk does not exist. There is always an inherent risk that, once measures and guarantees have been applied, is minimized, leaving a residual risk. Thus, all activities involving the processing of personal data always entail a risk for the individuals whose data is processed and, in particular, for their rights and freedoms. Even in those cases where the responsible party, either due to the type of data or the type of activity of the organization, could assume the existence of a low risk for the affected parties, this does not imply the automatic application of the sanctioning regime if that residual risk materializes.

In the present case, we are in a scenario of residual risk and more specifically regarding the rights and freedoms of the affected person. The dissemination of the data did not materialize over a multitude of uncontrolled individuals. Nor was the information published through open channels. The damages and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/27

The damages to the affected party are very relative. There is no risk of discrimination, identity theft, fraud, financial losses, or reputational harm. It was simply the sending of an email regarding a single person, identified and subject to confidentiality clauses and professional secrecy obligations. A mere fortuitous event.

At the same time, action was taken with extreme urgency to mitigate the impact, proceeding to its imminent correction through the rectification of the resolution, submission for the signature of the then Deputy Director General, and forwarding of the official communication to its correct recipient.

The Ministry asserts that in all matters relating to the processing of personal data, it is fully committed to the current legislation on personal data protection. In its role as the data controller, it processes personal data under its ownership for specific purposes and with the necessary confidentiality, observing the obligations imposed by personal data protection regulations, with special attention to technical and organizational measures to ensure data security and prevent alteration, loss, unauthorized processing, or access, taking into account the state of technology, the nature of the data processed, and the risks to which they are exposed.

In compliance with the aforementioned commitment of the Ministry to data protection, it indicates that it has:

- Internal policies and procedures to regulate the processing of personal data.
- An Inventory/Record of Processing Activities published on our electronic headquarters (<https://sedemissm.seg-social.es/proteccion-de-datos>)
- A Data Protection Officer, as a cornerstone of the data protection governance model.
- An adequate offer of training and awareness in data protection for employees and staff of the Ministry.
- Properly enabled internal channels for inquiries, complaints, and exercise of rights.
- Conducting risk analyses and Privacy Impact Assessments.

And that from the perspective of confidentiality as outlined in Article 5 of the LOPDGDD, it has a series of measures linked and/or associated with the dimension of confidentiality, among others:

- Identification and authentication systems.
- The requirements that individuals occupying the job position must meet in terms of confidentiality have been defined.
- A duty of confidentiality regarding the data to which they have access has been implemented, both during the period they are assigned to the job and subsequently after termination through the corresponding clauses.
- Due diligence and control are applied to the information media that remain under the responsibility of the organization, ensuring access control with physical measures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/27

- Appropriate technical and organizational measures have been applied to the treatment systems to ensure a level of security adequate to the risk, capable of guaranteeing confidentiality, integrity, availability, and permanent resilience.

Therefore, it maintains that only individuals and legal entities responsible for the acts constituting an administrative infringement can be sanctioned. In this specific case, we are faced with the commission of a human error by an official who at no time attempted to evade compliance with the protocols and procedures.

It also indicates that the instruction does not specify in its proposed resolution whether the outcome was due to intent or negligence. It does not determine the type of measure and/or security requirements that, had they been implemented, would have resulted in a different outcome.

Essentially, because there is no rational measure that, considering the state of the art, the costs of implementation, and the nature of the risk, can mitigate human error, which is one of the most difficult factors to foresee given the complexity of human nature, as well as other factors related to it such as procedures, the operational context affecting human operators, or management elements that promote human fallibility. Sanctions are simply imposed based on the outcome.

For example, this has been stated by the Constitutional Court in Judgment 164/2005 of June 20, affirming that "one cannot sanction merely based on the result and through apodictic reasoning, as a specific motivation regarding culpability or negligence and the evidence from which it is inferred is

essential." Also, in this regard, the National Court holds in Judgment of April 26, 2002 (Rec. 895/2009) that: "Indeed, one cannot affirm the existence of culpability based on the result."

Second: Proposal for sanction contrary to the Principle of Proportionality.

The Ministry understands that the proposed sanctioning resolution does not adhere to the principle of proportionality, proposing the imposition of two warnings for a simple human error.

Regarding the proposed sanction, it indicates that the requirements for the graduation of the sanction are not met, nor does it conform to the criteria established in the regulations, specifically those related in section three of Article 29 of Law 40/2015, of October 1, which states the following:

3. In the normative determination of the sanctioning regime, as well as in the imposition of sanctions by Public Administrations, the due suitability and necessity of the sanction to be imposed and its adequacy to the severity of the act constituting the infringement must be observed. The graduation of the sanction will particularly consider the following criteria:

- a) The degree of culpability or the existence of intent.
- b) The continuity or persistence in the infringing conduct.
- c) The nature of the damages caused.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/27

d) Recidivism, for the commission within a year of more than one infraction of the same nature when declared as such by a firm resolution in administrative proceedings.

In this case, the Ministry indicates in the sanctioning file that:

- a) There has been no culpability or intent on the part of the official who made the error in the notification act.
- b) There has been no continuity or persistence in the infringing conduct.
- c) The nature or extent of the damages caused is interpretable.
- d) There has been no recidivism.

In conclusion, it argues that the proposed sanction, especially considering it involves two warnings, is inadequate, unnecessary, and contrary to the principle of proportionality and criteria for the graduation of the sanction.

No corrective or preventive purpose is perceived in the instruction, only a punitive intent and the application of a punishment that is clearly excessive and disproportionate.

Third: Atypicality of the imputed conduct

The Ministry argues that the description of the facts and the legal qualification practiced do not fall under any of the cases defined as infractions, nor do the objective and personal circumstances determining legality and imputability exist, and that the Spanish Agency for Data Protection reproaches that the data has been processed in a manner that does not guarantee adequate security, through the application of appropriate technical or organizational measures (Integrity and Confidentiality).

In this regard, it indicates that Article 25.1 of the Constitution includes the rule "nullum crimen nulla poena sine lege," which presents a material guarantee derived from the mandate of definiteness (or "lex certa"), specified in the requirement that illicit conduct – and the corresponding sanctions – be normatively predetermined.

It invokes what the Constitutional Court has indicated (cf., for example, its judgment No. 242/2005, of October 10), regarding the fact that this material guarantee "implies that the punitive norm allows predicting with sufficient certainty the conduct that constitutes an infraction and the type and degree of sanction that may be imposed on those who commit it." Even more illustrative is what the Constitutional Court itself had the opportunity to recall in its ruling No. 148/2008, of June 9: the principle of typicity "not only prevents the imposition of sanctions for behaviors not provided for in the sanctioning norm but also prohibits analogy in peius and extensive interpretation in malam partem, that is, the exegesis and application of the norms outside the cases and limits that they themselves determine (among others, SSTC 81/1995, of June 5, F. 5 and 229/2007, of November 5, F. 4), which is

why the sanction provided can only be connected to the conduct that, by meeting all the elements of the described type, is objectively prosecutable."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/27

Article 27 of Law 40/2015 of October 1 establishes the principle of typicity, which consists of the necessity for normative predetermination of infringing behaviors and the corresponding sanctions. The principle of typicity unfolds in the theoretical plane through the explicit formulation of the constitutive facts of the infringement and its repressive consequences in the legal norm. However, in practical terms, this previous requirement entails the impossibility of qualifying a behavior as an infringement and sanctioning it if the actions or omissions committed by a subject do not bear a perfect similarity to those designed in the legal types.

It indicates that the actions of the Ministry cannot be subsumed under the type of Article 5.1.f of the GDPR, as the failure to adopt appropriate technical and organizational measures to ensure a level of security appropriate to the risk of processing, in the terms required by Article 32 of the GDPR, when the Ministry contemplates a whole set of measures as described in the first allegation.

It understands that there is no direct connection in terms of typicity and culpability between the breach of security measures and the violation of the duty of confidentiality. The Ministry implemented a security system that was breached due to a mere human error, which, as described in the written allegations regarding the initiation of the procedure, had never before occurred on the part of the official.

It indicates that it scrupulously complies with these provisions. In this sense, there are two core elements that support this and allow for the facts not to be subsumed under the conduct of violating the duty of confidentiality:

- The incident did not arise because a member of the Ministry failed to fulfill their confidentiality obligation and duty of secrecy by disseminating or disclosing information containing personal data without a legitimizing basis. Rather, it was simply due to a mere human error.
- Nor is it because the systems lack security measures that would guarantee the confidentiality of the data, nor because its personnel do not have a commitment or duty of confidentiality.

The Ministry points out that in our legal system, it is not permissible that, in a case such as the one at hand, the events that occurred can be considered constitutive of an infringement, based on an infringing type that does not fit the actions of the Ministry.

For all the above reasons, there is no action or omission on our part that bears similarity to the failure to adopt appropriate technical measures to ensure an adequate level of security, and therefore our conduct cannot be subsumed as an infringement of Articles 5.1F and 32 of the GDPR.

Fourth. - All allegations made in previous writings in the referenced procedure are reiterated.

For all the above reasons, the Ministry requests that the sanctioning file be dismissed with the consequent archiving of the proceedings.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/27

From the actions taken in the present procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: It has been established that the Ministry sent an email to a third party (C.C.C.), (...), a response letter in which personal information related to their employment circumstances (request for cessation, denial of cessation, etc.) appeared, specifically:

- That they have been appointed to a position of free designation in another Public Administration

without following the legally established procedure, specifically due to the lack of a favorable prior report from the originating Administration.

- That on May 4, 2021, the claimant was informed of an unfavorable report from the INSS.
- That the claimant reiterated the request for a report to the Ministry and that an unfavorable report was again issued dated May 31, 2021.
- It is indicated that there is a letter from the General Subdirector of Human Resources and Service Inspection of the Ministry, dated June 4, 2021, which communicates that the cessation of the claimant will not be formalized.
- It is indicated that the claimant has requested information on whether there is or is being processed an express resolution of their cessation in the originating Administration or, if applicable, whether a deferred cessation of three months has been requested, to which they are informed that their cessation will not be formalized in accordance with the letter of June 4, 2021.
- It is indicated that, subsidiarily to the above, the claimant has requested information regarding the reports issued concerning appointments in free designation made in the last four years within the ***POSITION.1.

SECOND: From the data contained in the response letter, the identity of the claimant can be easily deduced, as it indicates the details of the awarded position and the Bulletin where it has been published. In fact, this is what allowed the third party (C.C.C.) who received the letter by mistake to contact the claimant and inform them of it.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/27

Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), establishes that the Director of the Spanish Agency for the Protection of Data is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for the Protection of Data shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

In the present case, according to the provisions of Article 4.1 of the GDPR, there is evidence of the processing of personal data, given that the Ministry carries out, among other processes, the collection, registration, conservation, use, access, and deletion of the following personal data of individuals, such as: name and surname, identification number, contact details, telephone number, email address, employment circumstances, etc.

The Ministry carries out this activity in its capacity as the data controller, as it is the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR.

Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter security breach) as "all breaches of security that lead to the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or to the unauthorized communication or access to such data."

In this case, there is a personal data security breach under the circumstances indicated above, categorized as a confidentiality breach, as a letter containing information about the claimant's

employment circumstances was sent by email to a third party, which constitutes unauthorized communication of personal data.

Within the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data is guaranteed in paragraph 1.f) of Article 5 of the GDPR. For its part, the security of personal data is regulated in Articles 32, 33, and 34 of the GDPR, which govern the security of processing, the notification of a personal data security breach to the supervisory authority, and the communication to the data subject, respectively.

III

Claims Made

In relation to the claims made regarding the proposed resolution of this sanctioning procedure, a response is provided as follows:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/27

First.- Lack of culpability

The Ministry argues that it has acted neither with intent nor with negligence in relation to the data protection regulations, as it insists that the breach of confidentiality resulted from a simple material error by a person induced by the concurrent circumstances of the case, since it occurred due to the simultaneous processing of two applications with numerous similarities. It concludes that a mere human error cannot lead to the attribution of sanctioning consequences, as it would constitute objective liability.

Furthermore, the Ministry contends that there is no rational security measure that can mitigate human error, and therefore it is not appropriate to deduce that the security breach arises from the lack of adoption of adequate security measures, since the incident stems from a simple human mistake for which there are no reasonable protective measures commensurate with the risk, cost, and nature of the threat, as required by Article 32 of the GDPR, reiterating that there is no culpability, but rather a mere fortuitous event.

It should be noted that the GDPR in the aforementioned Article 32 does not establish a list of security measures applicable according to the data being processed, but rather states that the controller and the processor shall implement technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, as well as the risks of likelihood and severity for the rights and freedoms of the data subjects.

Moreover, the security measures must be adequate and proportionate to the identified risk, indicating that the determination of technical and organizational measures should be made considering: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification processes (not audits), evaluation, and assessment of the effectiveness of the measures.

In any case, when assessing the adequacy of the level of security, particular attention will be paid to the risks presented by the processing of data, as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

In this same vein, Recital 83 of the GDPR states: “(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the inherent risks of the processing and apply measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation with respect to the risks and the nature of the personal data that needs to be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the

destruction, loss, or alteration of personal data.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
17/27

accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data, particularly susceptible to causing physical, material, or immaterial damages and losses.” The Supreme Court, in its Judgment of 15/02/2022 (STS 543/2022), while indicating that the obligation to design and implement security measures to prevent potential security breaches is an obligation of means and not of results, also points out that it is not sufficient to design the necessary technical and organizational means; their correct implementation and appropriate use are also required, so that the responsible party will also be liable for the lack of diligence in their use and application. Regardless of whether a security breach is created by an unforeseen event or occurrence that the subject could not have avoided even by applying the strictest measures.

However, in the specific case, the Court concluded that the measures adopted by the appellant were insufficient and understood that the state of the art at the time of the events allowed for the establishment of more appropriate and adequate measures. The Court finally indicated that the fact that the leak occurred ultimately due to the negligent action of an employee did not exempt the company from its responsibility. For all these reasons, it confirmed the sanction imposed by the AEPD.

In the case at hand, against the allegation that it was due to a simple human error resulting from the similarity of the processed files and that there are no security measures to mitigate it, it should be noted that, precisely, in Public Administrations, the processing of similar files is common (for example, applications for subsidies, benefits, job provision procedures, etc.) and it is precisely in these cases where the risk of human error must be particularly assessed.

In the present case, confidentiality has been breached not as a result of an extraordinary or unusual activity of the Ministry but, on the contrary, within what is considered normal, ordinary, and habitual activity of the same. Human error is a risk that the data controller must assess when planning the processing, as the possibility of making mistakes is intrinsic to the human condition. The human factor, the evident possibility of making errors, is one of the most important risks to always consider in relation to the determination of security measures. The data controller must account for human error as a highly probable risk. Human errors are addressed and mitigated from a risk-based approach, through the analysis, planning, implementation, and control of adequate and sufficient technical and organizational measures.

There is always the possibility of implementing some procedural measure to reduce the risk, to minimize it as much as possible. However, in the present case, the Ministry has not demonstrated an assessment of the risk posed by human error nor any measures implemented to mitigate it, beyond indicating, in a generic manner, that it has implemented adequate measures in compliance with Article 32 and stating that there are no measures that mitigate or reduce human error.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
18/27

Therefore, in the present case, the responsibility of the Ministry is determined by the security incident highlighted by the claimant, as it is responsible for making decisions aimed at effectively implementing the appropriate technical and organizational measures to ensure a level of security adequate to the risk to guarantee the confidentiality of the data, restoring its availability and preventing access to it in the event of a physical or technical incident.

Regarding the alleged lack of culpability, it is noted that the emergence of sanctioning responsibility

presupposes the existence of culpability in any of its manifestations: intent, negligence, or slight negligence. In the field of Administrative Sanctioning Law, it is not possible to impose sanctions based on the objective responsibility of the alleged offender because administrative sanctions share the same nature as criminal ones, being one of the manifestations of the punitive power of the State and, as a requirement derived from the principles of legal certainty and criminal legality enshrined in Articles 9.3 and 25.1 of the Spanish Constitution (CE), it is essential that this element is present as a prerequisite for its imposition (STC 76/1999).

The principle of culpability is required in the sanctioning procedure, but the principle of fault does not imply that only intentional actions can be sanctioned. The Supreme Court (STS April 16, 1991, and STS April 22, 1991) considers that from the culpability element it follows “that the action or omission, classified as an administratively sanctionable infringement, must be, in any case, attributable to its author, by intent or negligence, imprudence, or inexcusable ignorance.” The same Court reasons that “it is not enough...for exculpation against a typically unlawful behavior to invoke the absence of fault” but it is necessary “that the diligence required by the one claiming its non-existence has been employed.” (STS January 23, 1998).

Furthermore, the National Court in matters of personal data protection has declared that “simple negligence or failure to comply with the duties imposed by law on those responsible for files or data processing to exercise due diligence is sufficient...” (SAN June 29, 2001).

The aforementioned ruling connects the reproachability to a legal entity for a certain conduct with the fact that it has or has not provided effective protection to the legal good protected by the norm. Given the circumstances of the case, it is evident that such diligence has not been observed in relation to the sending of documentation to a third party containing personal data to which they could access without the authorization of its owner.

Therefore, the conduct of the Ministry must be subject to reproach as a consequence of the breach of the regulations on personal data protection, both for the violation of the principle of confidentiality and for the breach or absence of adequate technical and organizational measures, by allowing access to the claimant's data without authorization.

The above is independent of whether subsequently the Ministry acted quickly to mitigate the impact of the breach of confidentiality. In this regard, concerning what was indicated by the Ministry itself regarding its actions...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/27

imminent repair through the rectification of the resolution and its submission to its correct recipient; however, it should be noted that this only meant that the corresponding documentation finally reached its correct recipient, but did not imply a remedy or mitigation of the impact of the breach of confidentiality that occurred.

Second.- Lack of proportionality in the imposed sanctions

The Ministry argues that the proposed sanctions do not adhere to the principle of proportionality, as two warnings have been established, without meeting the requirements for the graduation of sanctions set forth in section three of Article 29 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector.

In this regard, it should be indicated that Article 77 of the LOPDGDD “Regime applicable to certain categories of data controllers or processors” provides the following:

“1. The regime established in this article shall apply to the processing for which the following are responsible or act as processors:

c) The General Administration of the State, the Administrations of the autonomous communities, and the entities that comprise the Local Administration.

2. When the controllers or processors listed in section 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be

adopted to cease the conduct or correct the effects of the infringement that has been committed. Therefore, since the Ministry is a data controller belonging to the General Administration of the State, the cited provision applies to it. Thus, in the case of infringements of the GDPR, the sanction that must be imposed, by legal imperative, is that of a warning, and no other sanction is permissible, nor is it, by its very nature, subject to any criteria for graduation contained in the aforementioned Article 29 of Law 40/2015 or those established by the GDPR or the LOPDGDD.

Third.- Atypicality of the imputed conduct

The Ministry argues that the description of the facts and the legal qualification made do not fall under any of the cases defined as an infringement, invoking Article 25.1 of the Spanish Constitution, which requires that unlawful conduct - and the corresponding sanctions - be normatively predetermined, as well as Article 27 of Law 40/2015, which incorporates the principle of typicity. It argues again that everything was due to human error and that this does not imply a breach of confidentiality nor that the breach arises from a lack of adequate security measures.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
20/27

In this regard, it should be noted that the infringements related to data protection are defined in paragraphs 4, 5, and 6 of Article 83 of the GDPR. This is a definition by reference, fully accepted by our Constitutional Court. In this sense, Article 71 of the LOPDGDD also refers to them by stating that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 constitute infringements, as well as those that are contrary to this organic law.”

In this regard, the Opinion of the Council of State dated October 26, 2017, concerning the Draft Organic Law on the Protection of Personal Data states that “The European Regulation does indeed define, albeit in a generic sense, the behaviors constituting an infringement: indeed, paragraphs 4, 5, and 6 of its Article 83 contain a catalog of infringements for violations of the provisions of the European norm indicated in those paragraphs. Article 72 of the Draft Law rightly assumes the existence of such a catalog when it states that ‘acts and behaviors that constitute a violation of the content of paragraphs 4, 5, and 6 of the European Regulation and of this organic law constitute infringements.’”

The infringements established in Articles 72, 73, and 74 of the LOPDGDD are only for the purposes of prescription, as stated at the beginning of each of these provisions. This necessity arose in our State since there is no reference in the GDPR regarding the prescription of infringements, as this legal institution is not common to all EU Member States.

We must start from the premise that the GDPR is a directly applicable legal norm, which has been developed by the LOPDGDD only in what the former allows. This is evident regarding prescription in the preamble of the LOPDGDD when it states that “The categorization of infringements is introduced solely for the purpose of determining the prescription periods, with the description of typical behaviors having the sole purpose of exemplifying some of the sanctionable acts that must be understood as included within the general types established in the European norm. The organic law regulates the cases of interruption of prescription based on the constitutional requirement of knowledge of the facts attributed to the person.”

Therefore, the principle of legality enshrined in our legal system is perfectly fulfilled, as the behaviors considered unlawful and their corresponding sanctions are perfectly predetermined normatively. A different issue is that the Ministry does not agree that its conduct is considered to violate the data protection regulations, being subsumed under the infringements attributed, as has been reasoned throughout the sanctioning procedure and recorded in this Resolution.

Fourth.- The Ministry reiterates all the allegations made in previous writings in the sanctioning procedure.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

21/27

In this regard, it is indicated that all of them have already been addressed throughout the processing of the sanctioning procedure, being included in the Background of Facts of this Resolution, and therefore, it is appropriate to refer to them.

For all the above, the allegations put forward are dismissed.

IV

Article 5.1.f) of the GDPR

Article 5.1.f) "Principles relating to processing" of the GDPR establishes:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by means of appropriate technical or organizational measures ('integrity and confidentiality')."

In this case, it is established that the personal data of the complainant were improperly exposed to a third party (C.C.C.), (...) as an Official Letter containing information about the complainant's work circumstances was sent to them by email (...).

Although the complainant's name and surname do not appear directly, they are easily identifiable in that Official Letter as it mentions a nomination of theirs in the Official Bulletin of the City Council of Madrid. It was precisely C.C.C. who informed the complainant of the erroneous sending as they were able to identify them perfectly by that means.

In this sense, Article 4 of the GDPR, in its paragraph 1), defines "personal data" as: any information relating to an identified or identifiable natural person ('the data subject'); an identifiable natural person is one who can be identified, directly or indirectly, particularly by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person.

Therefore, this constitutes an unauthorized communication of personal data to third parties.

In light of the facts presented, it is considered appropriate to impose a sanction on the party being claimed for the violation of Article 5.1.f) of the GDPR as defined in Article 83.5 of the GDPR.

V

Definition of the infringement of Article 5.1.f) of the GDPR

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/27

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes the commission of the infringements typified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent pursuant to Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall be subject to a limitation period of three years, which involve a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

VI

Sanction for the infringement of Article 5.1.f) of the GDPR

Without prejudice to the provisions of Article 83.5 of the GDPR, the aforementioned article provides in its paragraph 7 the following:

"7. Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State."

For its part, Article 77 "Applicable regime for certain categories of controllers or processors" of the LOPDGDD provides the following:

"1. The regime established in this article shall apply to the processing for which they are responsible or which they process:

c) The General Administration of the State, the Administrations of the autonomous communities, and the entities that make up the Local Administration.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/27

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or to correct the effects of the infringement that has been committed.

3. Without prejudice to what is established in the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on the disciplinary or sanctioning regime that is applicable.

Likewise, when the infringements are attributable to authorities and executives, and the existence of technical reports or recommendations for processing that have not been duly addressed is proven, the resolution imposing the sanction shall include a reprimand naming the responsible position and shall order the publication in the Official State Bulletin or the corresponding autonomous bulletin.

4. The resolutions relating to the measures and actions referred to in the previous paragraphs shall be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article shall be communicated to the Ombudsman or, where appropriate, to the analogous institutions of the autonomous communities.

(...)"

Therefore, with the infringement of Article 5.1.f) of the GDPR confirmed, it is appropriate to sanction the Ministry with a warning.

VII

Article 32 of the GDPR

Article 32 "Security of processing" of the GDPR establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which shall include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

c) the ability to restore the availability and access to personal data quickly in the event of a physical or

technical incident;
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
24/27

d) a process of regular verification, evaluation, and assessment of the effectiveness of the technical and organizational measures to ensure the security of the processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law.

In this case, at the time of the breach, it cannot be asserted that the respondent used or had appropriate measures in place to prevent the incident and ensure confidentiality, as a response letter to a request made by the claimant was sent via email to a third party, which constituted unauthorized communication of personal data.

In light of the facts presented, it is considered appropriate to impose a sanction on the respondent for the violation of Article 32 of the GDPR as classified in Article 83.4 of the GDPR.

VIII

Classification of the violation of Article 32 of the GDPR

The aforementioned violation of Article 32 of the GDPR constitutes the commission of the violations classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"The violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 2% of the total annual global turnover of the preceding financial year, whichever is higher:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

In this regard, the LOPDGDD, in its Article 71 "Violations," establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute violations."

For the purposes of the limitation period, Article 73 "Violations considered serious" of the LOPDGDD indicates:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, violations that constitute a substantial breach of the articles mentioned therein are considered serious and shall be subject to a limitation period of two years, particularly the following:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679. (...)

IX

Sanction for the violation of Article 32 of the GDPR

Without prejudice to the provisions of Article 83.5 of the GDPR, the aforementioned article provides in its paragraph 7 the following:

"7. Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative

finances may be imposed on authorities and public bodies established in that Member State."

For its part, Article 77 "Applicable regime for certain categories of controllers or processors" of the LOPDGDD provides the following:

"1. The regime established in this article shall apply to the processing for which they are responsible or for which they are processors:

c) The General Administration of the State, the administrations of the autonomous communities, and the entities that make up the Local Administration.

2. When the controllers or processors listed in paragraph 1 commit any of the violations referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or correct the effects of the violation that has been committed.

3. Without prejudice to what is established in the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regimes that are applicable.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/27

Likewise, when the violations are attributable to authorities and executives, and it is proven that there are technical reports or recommendations for treatment that have not been duly addressed, the resolution imposing the sanction will include a reprimand naming the responsible position and will order publication in the corresponding Official State or regional Gazette.

4. The resolutions related to the measures and actions referred to in the previous sections must be communicated to the data protection authority.

5. The actions taken and the resolutions issued under this article will be communicated to the Ombudsman or, as applicable, to the analogous institutions of the autonomous communities. (...)

Therefore, having confirmed the violation of Article 32 of the GDPR, it is appropriate to sanction the Ministry with a warning.

Thus, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on the MINISTRY OF INCLUSION, SOCIAL SECURITY AND MIGRATIONS, with NIF S2801449F, for a violation of Article 5.1.f) of the GDPR classified under Article 83.5 of the GDPR, a sanction of WARNING.

SECOND: TO IMPOSE on the MINISTRY OF INCLUSION, SOCIAL SECURITY AND MIGRATIONS, with NIF S2801449F, for a violation of Article 32 of the GDPR classified under Article 83.4 of the GDPR, a sanction of WARNING.

THIRD: TO NOTIFY this resolution to the MINISTRY OF INCLUSION, SOCIAL SECURITY AND MIGRATIONS.

FOURTH: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Administrative Court of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Administrative Jurisdiction, within two months from the day following

the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation proving the effective filing of the administrative contentious appeal. If the Agency is not aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-010623

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/27